

IOL - Guide de mise en production

Architecture, securite des fichiers, reprise, CI et plan de bascule



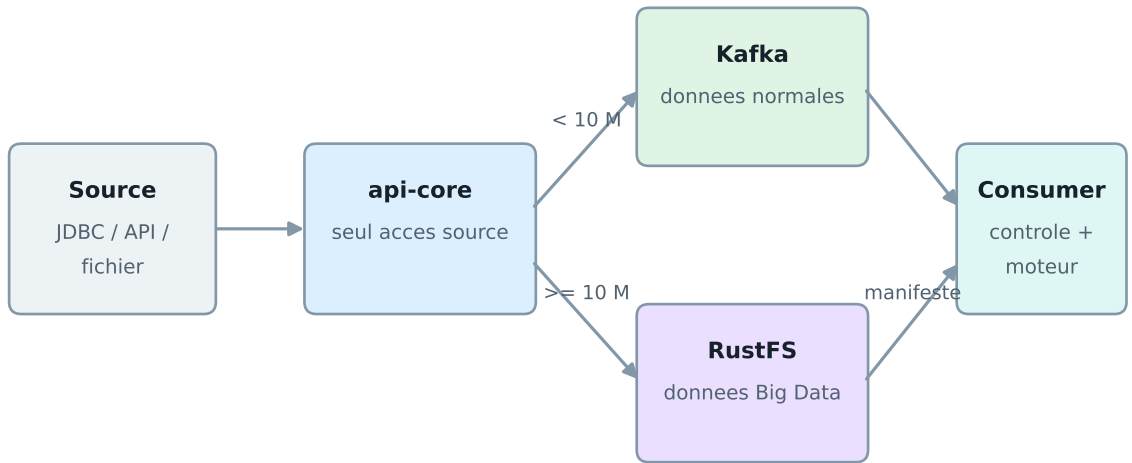
Objectif : passer d'une topologie de developpement fonctionnelle a une plateforme exploitable, securisee, observable et testee en charge.

Decisions deja implementees

- Basculement automatique a 10 millions de lignes ou 2 Gio.
- Aucun CSV JDBC : JSON type transporte par Kafka ou RustFS.
- Quarantaine ClamAV en mode ferme avec purge controlee a 30 jours.
- Sauvegarde validee par restauration isolee puis copie Restic hors site.
- Suppression RustFS apres succes et ACK Kafka ; retention d'echec de 72 h.
- Gemini et Groq en round-robin avec failover et contexte schema-only.
- Dialecte SQL resolu depuis la base de destination du workflow.

1. Decision automatique et transport

L'utilisateur choisit une intention, la plateforme choisit le moteur



Seuils initiaux de production

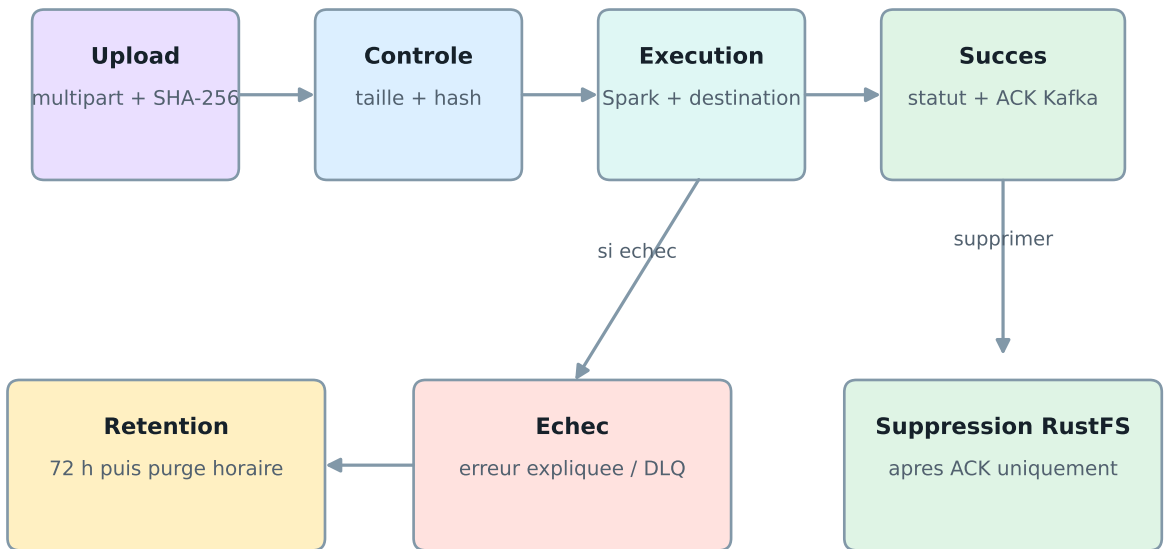
- JDBC : 10 000 000 lignes.
- Fichier : 2 Gio.
- Volume inconnu ou diagnostic expire : chemin Spark par prudence.
- Partie multipart RustFS : 64 Mio.
- Upload authentifie : 5 Gio, sans buffering Nginx.
- Evenement Kafka : 8 Mio maximum, limite de securite et non seuil Big Data.

Dimensionnement

Valider les seuils par tests de charge. Une partie de 64 Mio couvre environ 625 Gio avec 10 000 parties. Au-dela, augmenter la partie a 256/512 Mio ou decouper en plusieurs objets.

2. Cycle de vie RustFS

L'objet est temporaire, mais jamais supprime avant la fin sure du flow

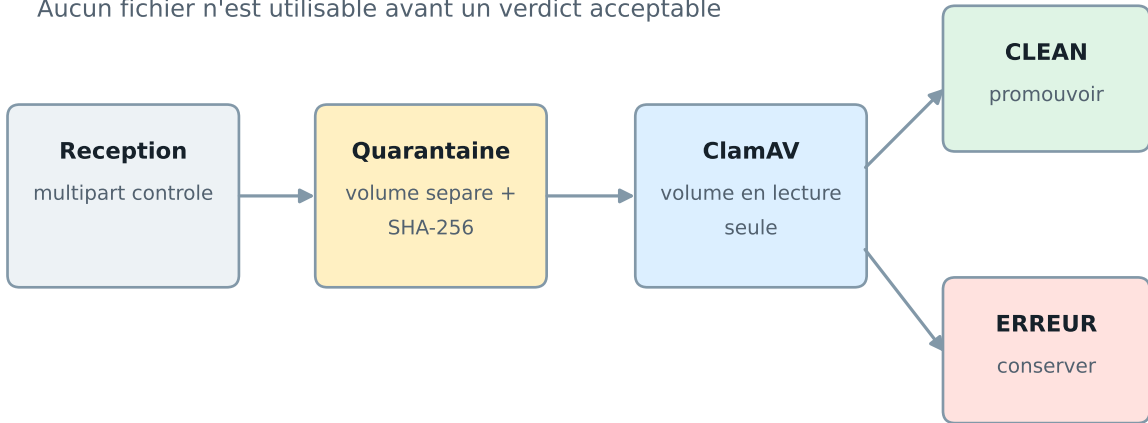


Ordre de securite

- Le consumer telecharge dans un chemin controle et verifie le SHA-256.
- Le fichier local est supprime dans le bloc de finalisation.
- Apres succes : statut terminal, ACK Kafka, puis suppression RustFS.
- Apres echec : conservation pour diagnostic et rejeu, maximum 72 heures.
- Bronze, Silver et Gold suivent la retention metier de la destination.

3. Quarantaine et ClamAV

Aucun fichier n'est utilisable avant un verdict acceptable



Comportement de production

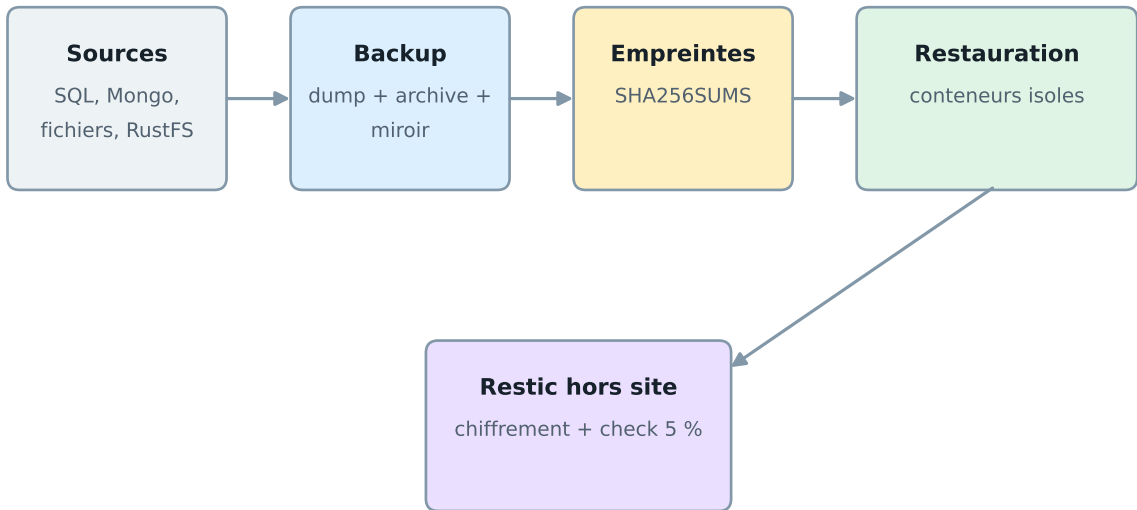
- fail-closed=true : scanner indisponible ou reponse incomplete = refus.
- Le workflow ne peut resoudre que les fichiers du volume approuve.
- La readiness API devient DOWN si ClamAV ne repond plus.
- Les dossiers UUID infectes ou en erreur sont purges apres 30 jours.
- La quarantaine est sauvegardee pour permettre l'analyse d'incident.

Limite explicite

ClamAV est limite ici a 2 Gio par fichier. Un upload direct plus grand reste bloque. Les charges JDBC/API massives utilisent RustFS ; les gros fichiers directs doivent etre decoupees ou passer par une future passerelle d'ingestion massive. Ne jamais desactiver le scan pour les accepter.

4. Sauvegarde prouvee par restauration

Le job reste en echec tant que la reprise n'est pas demontree



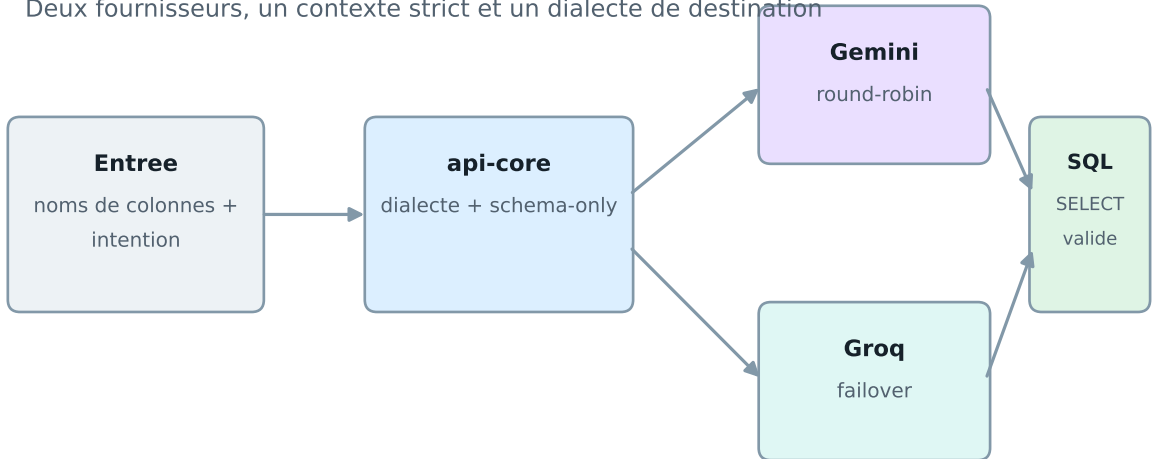
Cycle nocturne

- PostgreSQL est restaure avec `pg_restore --exit-on-error`.
- MongoDB IOL et OpenHIM sont restaures dans des instances temporaires.
- Les archives uploads et quarantaine sont relues.
- Le contenu RustFS est restaure dans un serveur objet isole.
- Restic envoie la copie chiffee hors site et controle un sous-ensemble.
- Le timer systemd est persistant et reprend un cycle manque.

Le script et sa syntaxe sont valides. Le proces-verbal de production doit encore contenir la preuve d'un cycle complet execute avec le stack actif.

5. IA SQL sans donnees

Deux fournisseurs, un contexte strict et un dialecte de destination



Informations autorisees

- Noms de colonnes et noms logiques de tables.
- Instruction fonctionnelle et type de generation.
- Nom du dialecte : PostgreSQL, MySQL, SQL Server, Oracle, SQLite, Snowflake ou Redshift.

Informations interdites

- Lignes, valeurs d'exemple, statistiques et donnees personnelles.
- Hote, URL JDBC, utilisateur, mot de passe ou cle technique.
- Chat generaliste : la route refuse toute demande hors generation SQL.

La rotation et le failover augmentent la disponibilite ; ils ne rendent pas les quotas illimites. Les cles sont injectees depuis un gestionnaire de secrets et ne sont jamais exposees au navigateur.

6. Fiabilite des livraisons OUTBOUND

Reprise multi-instance, poison pill et protection SSRF

Ledger MongoDB

claim atomique + lease +
statut terminal

Poison pill

JSON invalide vers DLQ puis
progression

Garde SSRF

HTTP(S), DNS, reseaux privés
et allow-list

Garanties implementees

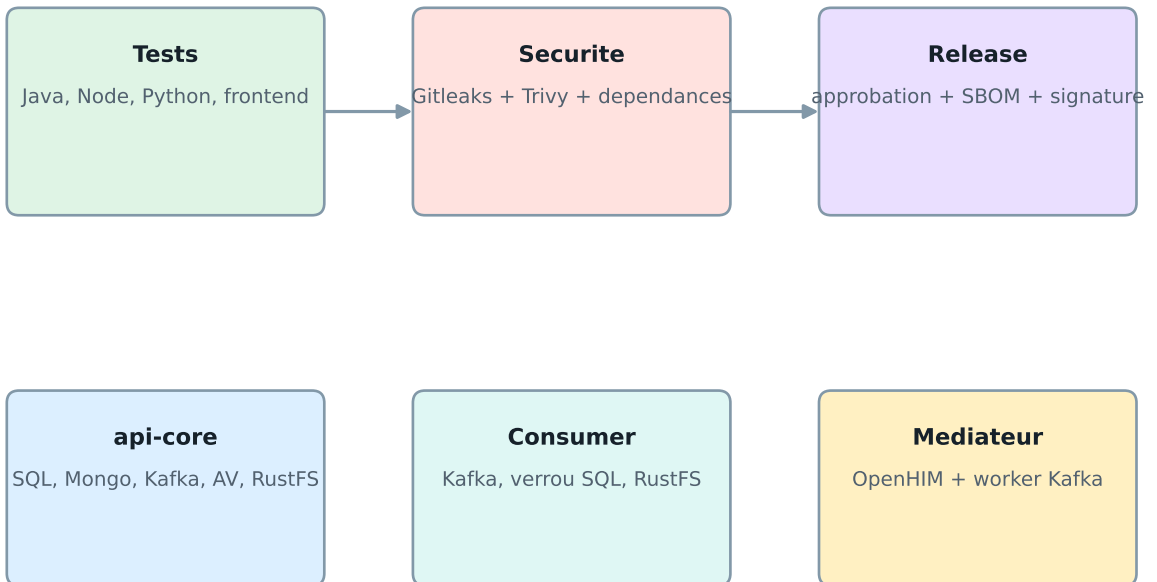
- La cle d'idempotence survit au redemarrage, au rebalance Kafka et aux replicas.
- Un worker ne peut reprendre un message actif qu'apres expiration de son lease.
- Un JSON corrompu est publie en DLQ et ne bloque pas la partition Kafka.
- Les credentials dans l'URL, localhost et les adresses privees sont refuses.
- La resolution DNS est controlee pour limiter les contournements par rebinding.

Garantie de bout en bout

Le worker transmet aussi Idempotency-Key au systeme cible. La cible doit persister cette cle : c'est la protection finale contre une coupure apres le POST mais avant la confirmation du ledger IOL.

7. Portes CI et probes runtime

Refuser un changement dangereux et retirer un composant indisponible



Regles

- Liveness controle seulement le processus.
- Readiness controle les dependances necessaires au nouveau travail.
- Une readiness DOWN retire l'instance du trafic sans boucle de redemarrage.
- La porte de qualite refuse toute verification en echec ou annulee.
- La branche main et l'environnement production-release exigent une approbation.

8. Modeles et partage multi-organisation

Simplifier l'usage sans promettre une isolation qui n'existe pas encore



Contrats de partage

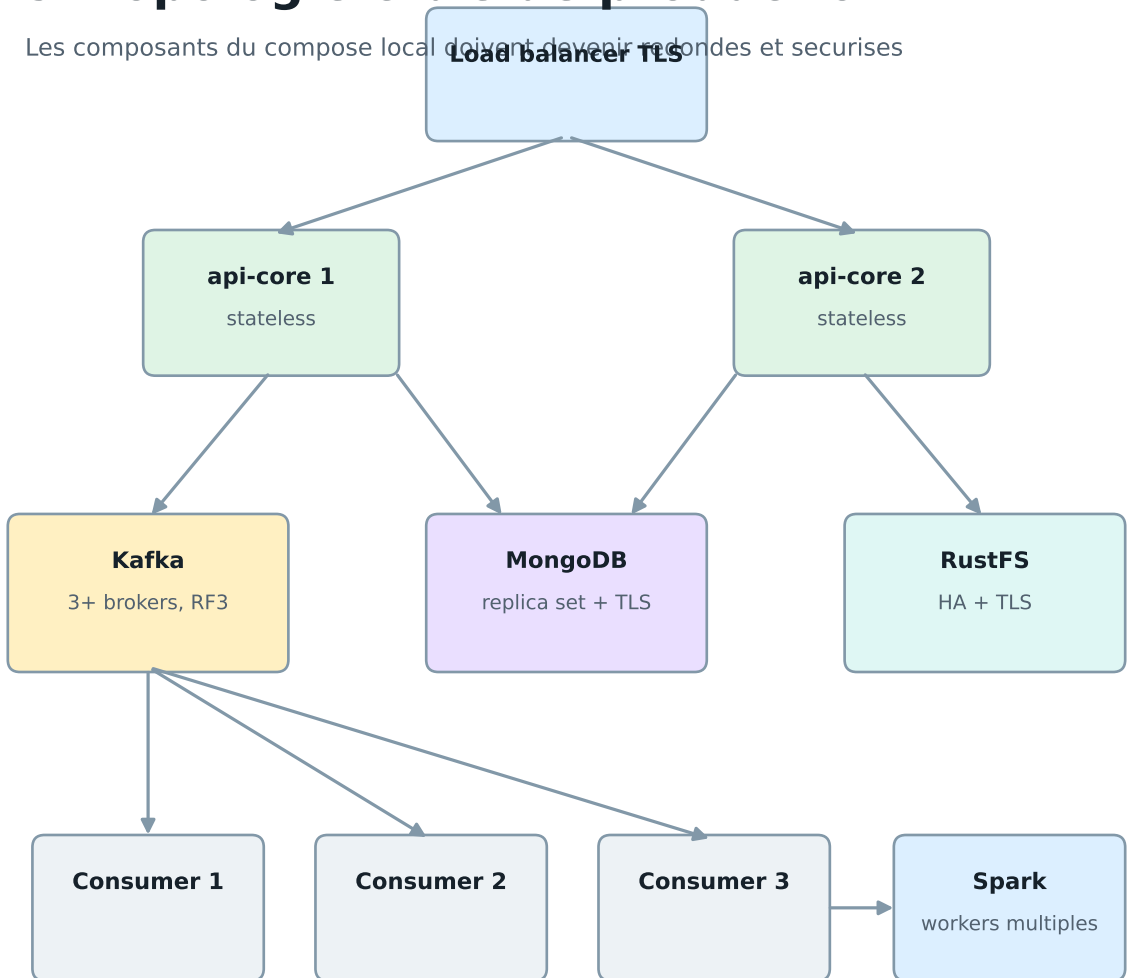
- Schema JSON pour organisations, finalite, champs, retention et interdictions.
- Enveloppe Kafka cible avec organizationId, contractId et correlationId.
- Exemple versionne hopital A vers hopital B valide en CI.

Garde-fou

Le contrat ne suffit pas a rendre IOL multi-tenant. Le runtime reste SINGLE_ORGANIZATION jusqu'a l'isolation JWT, SQL, Mongo, Kafka, RustFS, logs, sauvegardes et cles, accompagnee de tests negatifs. Les packs FHIR/DHIS2/SORMAS restent une phase ulterieure.

9. Topologie cible de production

Les composants du compose local doivent devenir redondés et sécurisés



Bloqueurs actuels

- Chiffrer les mots de passe source et destination avec KMS/Vault.
- Remplacer Kafka mono-broker PLAINTEXT et Mongo sans authentification.
- Configurer TLS, secrets uniques, sauvegardes et restauration testée.
- Epingler et scanner les images ; gérer les schemas avec Flyway/Liquibase.

10. Controle avant ouverture

La bascule est une preuve, pas seulement un changement de variables

Tests obligatoires

- Tests API, consumer et build frontend sans erreur.
- Fichier sain, EICAR, panne ClamAV et retour automatique de readiness.
- Cycle backup, restauration isolee et recuperation Restic sur un autre hote.
- 9,9 M puis 10,1 M de lignes ; fichier sous puis au-dessus de 2 Gio.
- Arret consumer, rejeu Kafka, idempotence et poison pill vers DLQ.
- Echec Spark : objet conserve ; succes : objet supprime apres ACK.
- Indisponibilite Gemini puis Groq, et failover dans les deux sens.
- Restauration MongoDB/PostgreSQL et repetition du retour arriere.
- Test SSRF, RBAC, secrets, TLS et journaux expurges.

Autorisation de mise en production

- Aucun secret dans Git, les images, le frontend ou les logs.
- Tous les bloqueurs de securite et de haute disponibilite sont fermes.
- SLA de charge et de reprise atteints avec les volumes reels.
- Dashboards, alertes, astreinte et procedures d'incident operationnels.
- Validation securite du traitement IA schema-only.

Verdict

Le code fournit les mecanismes de basculement, de retention et de failover. Le passage en production exige encore le durcissement de l'infrastructure et le chiffrement des credentials metier.